

계 획 서

과제명 : Leak Lens for Google Chat

팀명	CuTT
팀장	신동엽
팀원	최준서, 이태경, 최우중

1. 개발과제의 개요

오늘날 산업 현장에서 기업들은 ChatGPT와 같은 생성형 AI 플랫폼과 Google Chat, Slack 등 웹 기반 협업 메신저를 적극적으로 도입하며 생산성을 극대화하고 있습니다.

그러나 이러한 인프라 전환 과정에서 개발자의 소스코드 시스템 Key, 내부 기밀 문서, 개인 정보, 주소 등등의 민감 정보가 단순한 실수나 부주의로 인해 외부로 유출되는 보안 사고가 빈번하게 발생하고 있습니다. 취약점은 시스템적 결함보다 인적 오류(Human Error)에서 비롯되는 경우가 많으며, 그 파급력은 매우 치명적이라고 할 수 있습니다.

본 프로젝트는 이러한 인적 오류(Human Error)를 데이터 입력 단계에서 사전에 방지하기 위해, 웹 브라우저 환경에서 동작하는 프로그램을 개발하는 것을 목표로 합니다.

이 시스템의 핵심은 시스템 부하와 API 비용을 최소화 하는 데 있습니다. 1차적으로 정규표현식(Regex)기반의 필터를 통해 일상 대화(노이즈)를 걸러내고, 의심되는 데이터에 대해서만 LLM 기반의 2차 맥락 분석을 수행합니다. 사용자가 텍스트를 입력하고 전송하기 전 Debounce 기법을 적용하여, 백그라운드에서 위험도를 실시간으로 평가하여 비동기 스택(Stack) 형태의 팝업 Toast Notification)으로 경고를 제공합니다.

이를 통해 작업 흐름을 방해하지 않으면서도 강력한 사전 차단 및 교육 효과를 달성합니다.

2. 과제의 필요성 및 기대효과

(1) 기존 기술(과제)의 현황, 문제점 및 개선방안

현황 및 문제점 : 현재 산업 현장의 주요 보안 시스템(DLP 등)은 주로 네트워크 트래픽이나 사후 로그 분석에 치중되어 있습니다.

사전에 감지하는 솔루션이 존재하더라도 단순 정규표현식(Regex)에 의존하여 '숫자 16자리'나 특정 키워드가 포함되면 맥락을 불문하고 기계적으로 차단하는 방식이 주를 이룹니다.

이는 다음과 같은 심각한 문제를 야기할 수 있습니다.

첫째, 높은 오탐률(False Positive)입니다. 실제 유출이 아닌 보안 교육 목적의 대화나, 가상의 더미 데이터를 공유하는 상황에서도 경고가 발생하여 개발자와 직원의 피로도를 급증시킵니다.

둘째, 사후 대응의 한계입니다. 이미 데이터가 전송된 후에 관리자에게 통보되는 시스템은 정보 유출을 원칙적으로 막지 못하며, 영국 우체국 사태처럼 시스템 오류나 단순 실수로 인한 치명적인 피해를 예방할 수 없습니다.

개선방안 : 본 프로젝트는 엔드포인트(사용자의 브라우저)에 직접 밀착하는 크롬 익스텐션 방식을 채택합니다.

해당 프로젝트는 크게 두 가지의 개선점을 가지는데,

1. 하이브리드 탐지 : 가벼운 정규식으로 1차 필터링을 거친 후, 의심되는 데이터만 LLM API로 전송하여 맥락(Context)을 분석하므로 오탐률을 획기적으로 낮추고 시스템 부하를 줄입니다.

2. UX 친화적 개입 : 비동기식 알림 Toast Notification) 및 디바운스 기법을 사용하여, 사용자가 타자를 치는 동안 지연 없이 백그라운드에서 분석을 수행하고 즉각적인 피드백을 제공합니다.

3. SPA 대응 및 엔드포인트 밀착 모니터링 : Google Chat과 같은 동적 웹앱의 DOM 변화를 Mutation Observer로 실시간 감지하여, 사용자가 어느 채팅방으로 이동하든 지속적인 보안 감시망을 제공합니다.

(2) 과제개발 혹은 제작에 따른 기대효과

1. 민감 정보 유출의 원천적 사전 차단 : 외부 서버로 전송되기 전, 클라이언트 단에서 즉각적인 경고가 이루어져 휴먼 에러에 의한 치명적인 보안 사고를 방지합니다.
2. 보안 시스템의 스마트화 (오탐률 감수) : 맥락 인식 AI를 도입하여 불필요한 알람을 줄이고, 실제 위험도가 높은 상황에만 경고하여 보안 시스템의 신뢰도를 높입니다.
3. 자연스러운 보안 교육 효과 : 위험 사례 발생 시 팝업을 통해 구체적인 사유를 제공하여 직원의 보안 인식을 실시간으로 강화합니다.
4. 안전한 AI/협업 툴 전환 가속화 : 기업이 보안 우려 없이 AI 툴 및 메신저를 도입할 수 있는 신뢰 환경을 구축하여 생산성 향상에 기여합니다.
5. API 비용 및 시스템 리소스 최적화 : 모든 텍스트를 LLM에 보내는 대신 1차 정규식 필터와 사용자 입력 지연(Debouncing) 기술을 결합하여 무의미한 API 호출 비용을 절감하는 경제적인 시스템을 구축합니다.

3. 과제목표 및 내용

최종 목표 :

본 프로젝트의 최종 목표는 산업 현장에서 즉시 활용 및 검증이 가능한 수준의 AI 기반 맥락 인식 정보 유출 방지 크롬 익스텐션 MVP를 구현하는 것입니다.

1. 텍스트 추출 및 모니터링 : 특정 웹사이트(Google Chat 등)의 텍스트 입력창 이벤트를 감지하여 실시간 텍스트 데이터화
2. Pre-filter (1차 필터링) : 비용 및 속도 최적화를 위해 특정 키워드(key, password, 특정 코드 심볼)가 포함된 경우에만 2차 분석으로 이관
3. 디바운싱 적용 텍스트 추출 : 사용자가 타이핑하는 때 순간이 아닌, 입력이 약 1초간 멈추는 시점을 포착하여 순수 텍스트만을 추출 및 전송
4. AI 맥락 기반 위험도 평가 : LLM API를 활용하여 페르소나 및 Few-shot 프롬포팅이 적용된 LLM에 데이터를 전송하여 실제 유출 위험도와 그 사유를 JSON

형태로 반환

5. 비동기 경고 스택 제공 : 분석 결과가 '경고'일 경우 화면 우측에 알림을 스택 형태로 누적 표시

비기능적 요구사항 :

1. 비용 및 리소스 최적화 : 무분별한 API 호출 방지를 위한 디바운스(Debounce) 및 1차 정규식 필터링 필수 적용

2. 성능 : 메인 스레드를 블록킹하지 않도록 비동기로 API 호출 수행

3. 확장성 : 향후 사내 규정 등 커스텀 데이터베이스 연동이 용이하도록 모듈화된 아키텍처 설계

4. 사용성 : 경고 알림은 사용자의 시야를 완전히 가리지 않는 크기와 색상을 적용하여 거부감을 줄이도록 설계

4. 추진전략 및 방법

(1) 추진전략 및 방법

본 프로젝트는 빠르고 효율적인 프로토타입 구현을 위해 애자일 방법론과 최신 AI 개발 트렌드인 라이브 코딩을 적극 차용합니다.

1. MVP 중심 애자일 & 라이브 코딩 : 복잡한 백엔드 서버 구축을 배제하고, AI 코딩 어시스턴트를 활용하여 프론트엔드와 Open API 통신 로직을 최우선으로 빠르게 프로토타이핑합니다.

2. 단계별 개발 방법 :

Phase 1 : UI/UX(토스트 알림) 및 DOM 텍스트 추출 로직 뼈대 구축

Phase 2 : 1차 필터링(정규표현식) 모듈 개발 및 성능 테스트

Phase 3 : LLM API 연동, 사이버 보안관 페르소나 프롬프트 엔지니어링

3. 자료 수집 방안 : 오픈소스 저장소 등에 실수로 커밋된 API Key 형태, 개발자 커뮤니티의 실수 사례 등을 공개된 보안 취약 패턴을 수집하여 프롬프트 예시 데이터로 활용

(2) 추진체계

본 프로젝트는 4인 1조로 구성되어 있고, 효율적인 바이트 코딩 및 목표 달성을 위해 다음과 같이 역할을 세분화합니다.

- 신동엽 (System Architecture & PM) : 프로젝트 총괄 및 일정 관리, 하이브리드 탐지 파이프라인 설계, 크롬 익스텐션 뼈대 구축 및 비동기 이벤트 제어 총괄.
- 최준서 (Prompt Engineering & API Integration) : LLM 연동 최적화, 페르소나 설계 및 Few-Shot 프롬프트 고도화, AI의 출력 결과를 프론트엔드에서 활용할 수 있도록 JSON 파싱 로직 구현.
- 이태경 (Frontend & UI/UX) : Content.js를 활용한 SPA DOM 감지 및 비동기 Toast Notification Stack UI/UX 상세 설계.
- 최우중 (Data Pipeline & Regex Rules) : 1차 필터링용 민감 정보 정규식 세트 구축, 모의 테스트를 위한 더미 데이터셋 생성 및 시나리오별 오탐률/성능 검증.

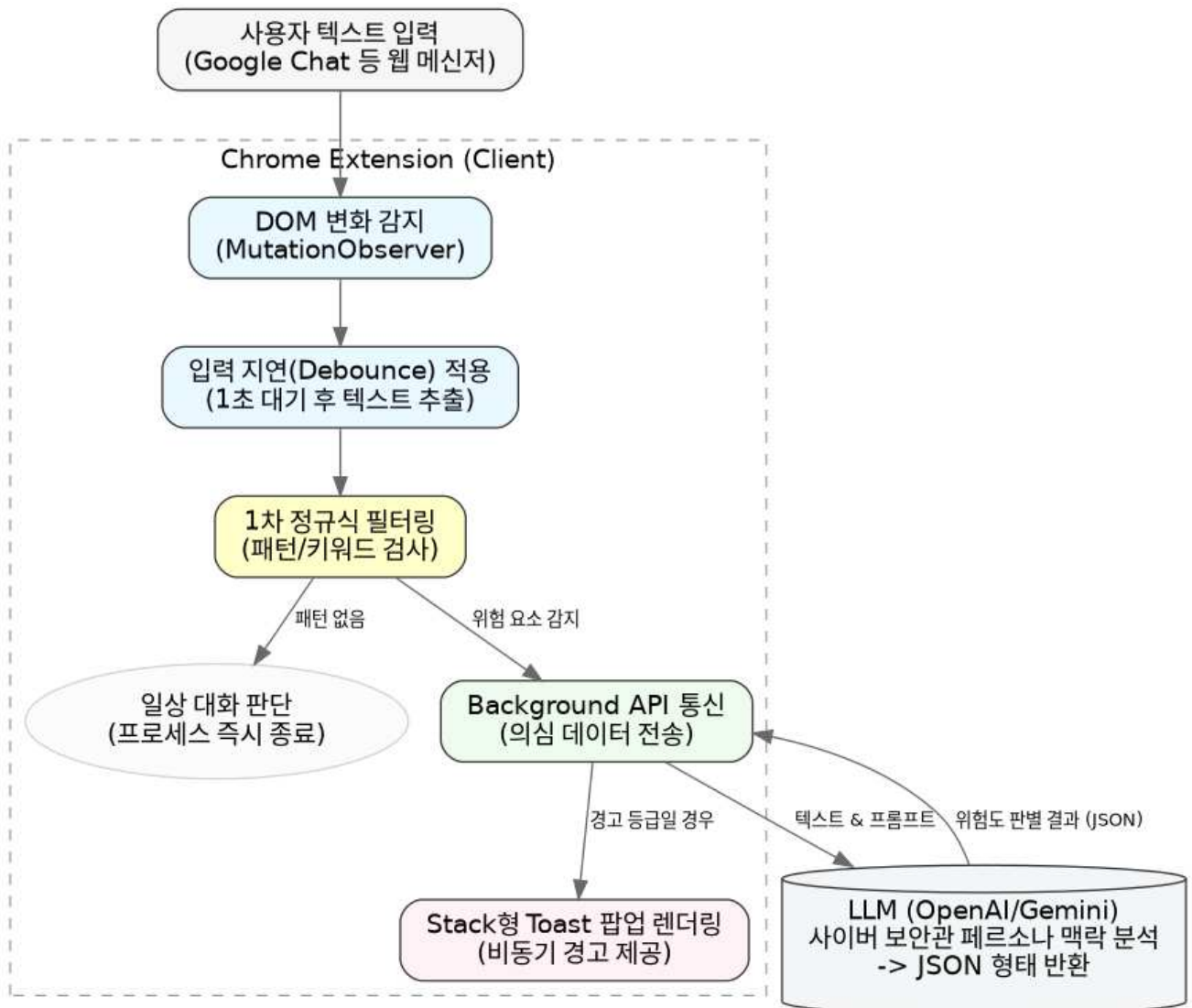
다음 역할로 세분화 하였으나, 필요에 따라 이태경, 최우중은 Frontend와 Backend를 넘나들면서 피드백 수용, 반영등을 통해 유연하게 작업할 예정.

5. 추진일정

세부내용	수행기간(주)															비고
	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	
크롬익스텐션 뼈대																
1차 필터링 룰셋 구축																
디바운싱 및 UI 구현																
LLM API 연동 및 프롬프트 고도화																
실험 데이터 생성 및 통합																
시나리오 기반 모의 테스트 진행																
최종 버그 픽스, 문서화 및 결과 보고																

6. 참고문헌

1. NIST Special Publication 800-137, "Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations", 미국 국립표준기술연구소(NIST) (지속적 모니터링 및 실시간 위험 평가의 이론적 근거)
2. OWASP (Open Worldwide Application Security Project), "OWASP Top 10 for Large Language Model Applications", 2023 (LLM 환경에서의 민감 정보 유출 방지 및 보안 가이드라인)
3. Google Developers, "Chrome Extension Manifest V3 API Reference" (Content Script와 Background Script 간의 비동기 메시지 패싱 및 MutationObserver API 공식 문서)
4. "Prompt Engineering for Context-Aware Information Extraction", 관련 AI 컨퍼런스 및 DeepLearning.AI 가이드 (Few-shot 프롬프팅 및 페르소나 설정을 통한 오답률 감소 기법)
5. David Walsh, "JavaScript Debounce Function", 프론트엔드 엔지니어링 최적화 기법 (API 과금 방지 및 DOM 이벤트 제어를 위한 디바운싱 알고리즘)



- 본 시스템은 클라이언트 측의 경량화 된 처리 구조와 외부 AI API의 결합을 통한 하이브리드 탐지 아키텍처로 설계되었습니다.

1. 텍스트 추출 및 지연 평가 (Content Script & Debounce) :

사용자가 Google Chat 등의 입력창에 텍스트를 작성하면 MutationObserver가 이를 감지합니다. 시스템 부하를 막기 위해 타자가 약 1초간 멈추는 시점 (Debounce)을 '입력 완료'로 판단하여 텍스트를 추출합니다.

2. 1차 필터링 (Pre-Filter / Regex 기반) :

추출된 텍스트는 익스텐션 내부의 정규표현식 엔진을 거칩니다. 위험 키워드나 패턴이 없는 '일상 대화'는 여기서 즉시 처리 종료되어 API 통신 비용을 0원으로 만듭니다.

3. API 통신 및 맥락 분석 (Background.js & LLM): 1차 필터에서 의심 패턴이 발견되면, 백그라운드 스크립트가 해당 텍스트를 LLM API로 전송합니다. 이때 단순 텍스트가 아닌 '사이버 보안관 페르소나'와 'Few-shot 예시'가 포함된 시스템 프롬프트가 함께 전달되어 텍스트의 실제 유출 맥락을 분석합니다.

4. 비동기 UI 피드백 (Toast Notification) :

LLM이 분석한 위험도 및 사유를 바탕으로, 위험으로 판별된 경우에 즉시 화면 우측에 비동기 스택형 알림을 렌더링하여 사용자에게 경고와 수정 가이드를 제공합니다.